Flag 8 of 18: Deleted MFA Alert Email

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

To prevent the compromised employee from noticing the persistence mechanism, the adversary abused a newly authorized third-party OAuth application to permanently purge security notifications from the victim inbox. What is the exact subject line of the first permanently deleted email, which alerted on multi-factor authentication changes?

Answer

Okta: A new MFA factor was added

Evidence

- Log type `WORKSPACE_ACTIVITY`, product `gmail`, event type `EMAIL_TRANSACTION`, Cymbal namespace.
- Mailbox: `elena.rostova@cymbal-investments.com`. Event timestamp `22:03:14Z`; the list view showed 23:03:14.
- It was the only email in the window whose subject matched an MFA-change pattern.
- The ShinyHunters bulletin described the actor enabling the ToggleBox Recall add-on and deleting a "Security method enrolled" email. The subject in Cymbal logs was worded differently, so the bulletin was a hint, not the answer.

How it was found

Window: Oct 15 20:00 to Oct 19 00:00 UTC. A user-based search found nothing, so the search switched to subject keywords:

```
principal.namespace = "Cymbal"
AND (additional.fields.value.string_value = /security
method|enrolled|MFA|factor|authenticator/ nocase
     OR network.email.subject = /security
method|enrolled|MFA|factor|authenticator/ nocase)
```

One result came back.

Lesson

Use threat intelligence to decide what to search for, then copy the exact value from the event. When a user filter fails, search by content.

Next pivot

Find what the attacker accessed with the hijacked session, starting from the attacker proxy IPs.